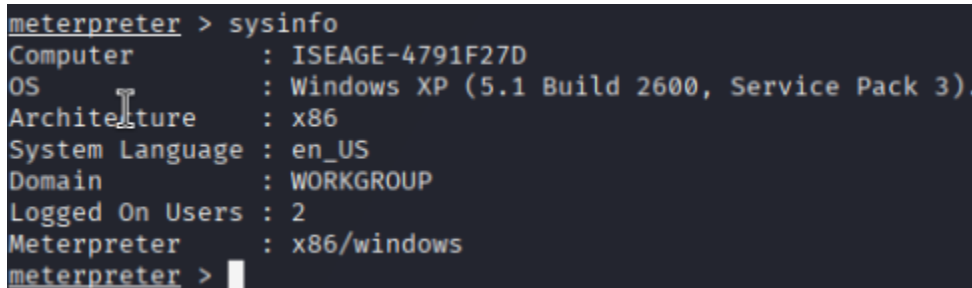


Lab Template

1. Screenshot of the command “sysinfo” on the Windows XP machine
(10 points)



```
meterpreter > sysinfo
Computer      : ISEAGE-4791F27D
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > 
```

2. Identify at least five commands that could be used in an attack. Explain how each of these five commands could be useful to you as an attacker.
(10 points)

Ans) 5 commands that could be used in an attack are:

- 1) Hashdump: It is basically the process of extracting password hashes and other important credentials from a computer's memory or database. It can be used by attackers because of the following things:
 - Lateral Movement: It allows the hackers to move from one machine to another laterally, as the attackers can use the passwords stolen during the Pass-the-hash attacks to actually log in to other machines without needing a plaintext password.
 - Offline Password cracking: It allows the attacker to steal the hashes offline and reveal the original plaintext passwords.
- 2) Getsystem: It employs many privilege escalation (it occurs when an attacker higher level permission than he originally had) tactics to grant adversaries access to a victim's SYSTEM account. This command is useful for an attacker as the SYSTEM privileges allow him to access files, read protected documents, install services, etc., actions which are usually performed by the administrators.
- 3) Keyscan_start/keyscan_dump: It basically captures the keystrokes that are typed on a machine which can be used later to reveal any sensitive information and for the very same reason it is useful for an attacker since it reveals passwords, private chats or any other sensitive information.

- 4) Webcam_scam/webcam_stream/record_mic/screenshot: It basically captures images from the webcams on a desktop, streams video, records whatever a person says on their microphone, and grabs screenshots of the desktop as well. This command can help the attacker gather information about a user's online activity and the environment in which they work in real-time.
- 5) Portfwd (Port forwarding): It is a technique that allows the packets to be transferred from a compromised port to another port on the targeted network. It's useful for lateral movement as it allows the attacker to mark the compromised machine as a pivot point and reach any internal services or machines that aren't reachable from his own network.

3. Run "getuid". What user are you running as? What permissions does this user have?

(10 points)

Ans) I am running as "NT AUTHORITY\SYSTEM", which is a built-in Windows account that has unrestricted access to all local system resources and is more powerful than any admin account. Since it is a built-in member of the Windows Administrative Group on the local computer so that means it is also a member of the SQL Server sysadmin fixed server role. Most of the system-level services and some other 3rd party services run on this account, and other accounts do not have enough rights for some services.

4. Identify two more post-exploitation commands and explain how the information could be used.

(10 points)

- 1) run post/multi/gather/env: The env module basically collects and displays the OS variables on the compromised machine. It is useful for an attacker because it can help an attacker in the following ways:
 - Discovering credentials: Attackers can use the environment variables to store any critical configuration settings, and attackers can also use this information to access other services as well.
 - Locating paths and resources: These variables can also reveal the target system's paths, any type of software that are installed, and network configuration too.
 - Understanding the system: It can reveal all the information about the OS and other system settings. It helps the attackers in choosing the most effective tools and makes a better attempt at hacking stuff in the future

2) run post/windows/manage/migrate: This module basically migrates to a specified process, or if none is given, it will make a new process and migrate to it.

- Avoid losing the session: If the attacker is able to migrate to a more stable process, which might be running in the background, the attacker can maintain persistent access; otherwise, he loses his session once the user closes his browser.
- Bypasses security software: If we are able to inject malicious code into the memory of a trusted or legitimate process, then the Meterpreter payload comes in and makes it very difficult for security software to detect it.
- Accesses Sensitive data: If the attacker gains administrative rights, they can use the migrate module to move their session to the lsass.exe process (It is a core part of the Windows security that enforces password and account policies, issues access tokens, etc.). Once the attacker is inside this process, he can use hashdump to extract user passwords and later use it for lateral movement.

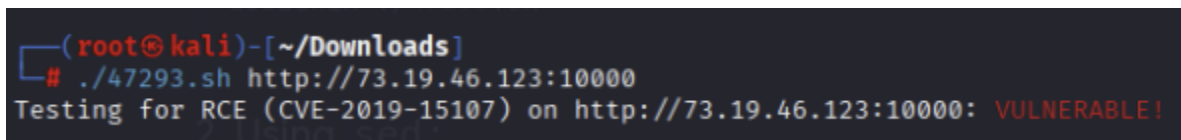
5. What is this service running on port 10000? What is it used for? (3 sentences minimum)

(10 points)

Ans) We are using the webmin service over here. Webmin is a web-based administration tool program that simplifies the process of managing a Linux or Unix system. Normally, we have to edit the configuration files manually, run commands to create and set up web servers, which usually takes a lot of time and effort. Webmin basically provides us with an interface which is easy to work upon and automatically updates all the configuration files for us which makes our job way more easier.

6. Run the script ./47293.sh. Take a screenshot of the output that confirms the machine is vulnerable.

(10 points)



```
(root@kali)-[~/Downloads]
# ./47293.sh http://73.19.46.123:10000
Testing for RCE (CVE-2019-15107) on http://73.19.46.123:10000: VULNERABLE!
```

7. Answer the following questions about CVE-2019-15107:

(10 points)

- a. How did this vulnerability come to exist?

Ans) This vulnerability came into existence as some malicious actors injected some bad code into Webmin's official builds(which is usually a packaged version of a program that we can download and run), which led to some weird password-change request commands on their server.

- b. *What version of Webmin was initially released with this vulnerability enabled by default?*

Ans) Webmin version 1.890 was initially released with CVE-2019-15107 enabled by default.

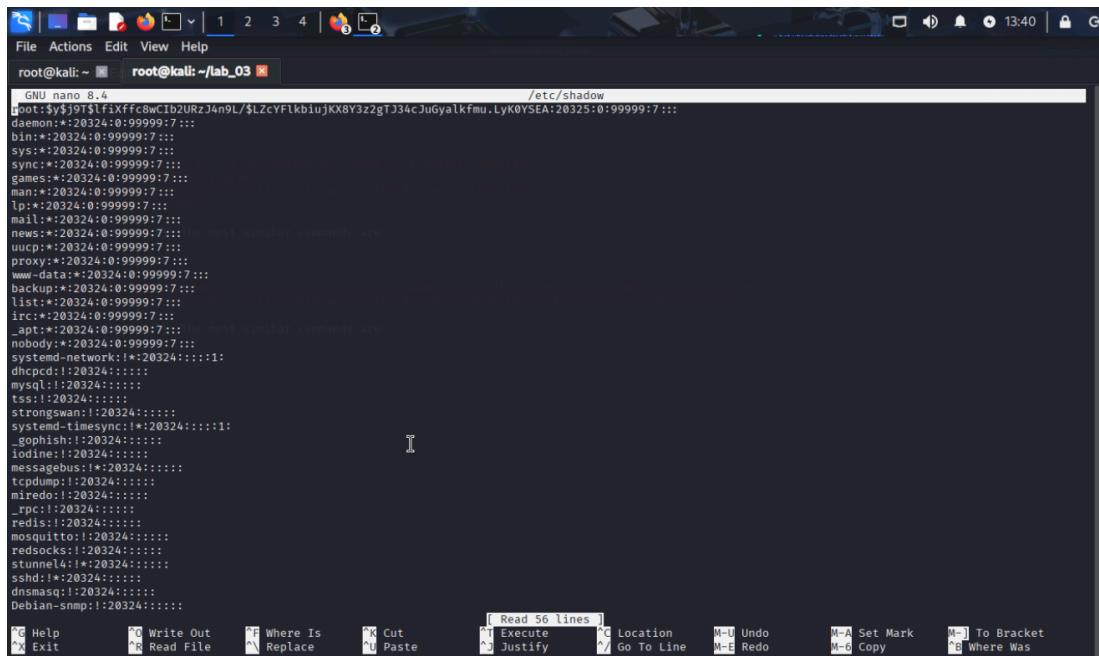
- c. *What user does the remote code injection run as?*

Ans) Usually, any command that runs through a backdoor(it is a malicious code that an attacker inserts before it reaches any of the company's users) has root-level privileges, so we can say that the attacker attains root-level privileges when running the remote code injection.

- d. *How severe is this CVE based on NVD CVSS 3.X standards?*

Ans) Based on NVD CVSS 3. X standards, this vulnerability has a base score of 9.8, which means that it is critical.

8. Take a screenshot of you reading /etc/shadow on X.X.X.123 (5 points)



The screenshot shows a terminal window with a dark background. The prompt is 'root@kali: ~'. The user has entered the command 'cat /etc/shadow'. The output displays the contents of the shadow file, showing usernames and their corresponding encrypted passwords and metadata. The entries are: daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list, irc, _apt, nobody, systemd-networkd, dhcpcd, mysql, tss, strongswan, systemd-timesyncd, _gophish, iodine, messagebus, tcpdump, miredo, _rpc, redis, mosquitto, redsocks, stunnel4, sshd, dnsmasq, and Debian-snmpp. The terminal window has a menu bar at the top with 'File', 'Actions', 'Edit', 'View', and 'Help'. At the bottom, there is a status bar with various keyboard shortcuts like 'H-? Help', 'W-? Write Out', etc.

```
root@kali: ~  
cat /etc/shadow  
daemon:*$5$9T$!fXfrcwIb2URzJ4n9L/$LZcYfLkbIuJKX8Y3z2gTJ34cJu6yalkfmu.LyK0Y5EA:20325:0:99999:7:::  
bin:*:20324:0:99999:7:::  
sys:*:20324:0:99999:7:::  
sync:*:20324:0:99999:7:::  
games:*:20324:0:99999:7:::  
man:*:20324:0:99999:7:::  
lp:*:20324:0:99999:7:::  
mail:*:20324:0:99999:7:::  
news:*:20324:0:99999:7:::  
uucp:*:20324:0:99999:7:::  
proxy:*:20324:0:99999:7:::  
www-data:*:20324:0:99999:7:::  
backup:*:20324:0:99999:7:::  
list:*:20324:0:99999:7:::  
irc:*:20324:0:99999:7:::  
_apt:*:20324:0:99999:7:::  
nobody:*:20324:0:99999:7:::  
systemd-networkd:!:20324:0:99999:7:::  
dhcpcd:!:20324:0:99999:7:::  
mysql:!:20324:0:99999:7:::  
tss:!:20324:0:99999:7:::  
strongswan:!:20324:0:99999:7:::  
systemd-timesyncd:!:20324:0:99999:7:::  
_gophish:!:20324:0:99999:7:::  
iodine:!:20324:0:99999:7:::  
messagebus:!:20324:0:99999:7:::  
tcpdump:!:20324:0:99999:7:::  
miredo:!:20324:0:99999:7:::  
_rpc:!:20324:0:99999:7:::  
redis:!:20324:0:99999:7:::  
mosquitto:!:20324:0:99999:7:::  
redsocks:!:20324:0:99999:7:::  
stunnel4:!:20324:0:99999:7:::  
sshd:!:20324:0:99999:7:::  
dnsmasq:!:20324:0:99999:7:::  
Debian-snmpp:!:20324:0:99999:7:::
```

```
(root@kali)-[~/lab_03]
# scp repo@repo.homework.2310.com:~/lab_03/WEB.sh
usage: scp [-346ABCOpqRrsTv] [-c cipher] [-D sftp_server_path] [-F ssh_config]
        [-i identity_file] [-J destination] [-l limit] [-o ssh_option]
        [-P port] [-S program] [-X sftp_option] source ... target

(root@kali)-[~/lab_03]
# sudo nano /etc/shadow
Margarette (mom)
```

9. What is the EoL date of this Ubuntu release on X.X.X.104?
(5 points)

Ubuntu	Quantal Quetzal	Release notes	October 18, 2012	May 16, 2014
12.10				

```
scrat@ISEage:~$ groups
scrat
scrat@ISEage:~$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 12.10
Release:        12.10
Codename:       quantal
scrat@ISEage:~$ uname -a
Linux ISEage 3.5.0-17-generic #28-Ubuntu SMP Tue Oct 9 19:31:23 UTC 2012 x86_64 x86_64 x86_64 GNU/Linux
scrat@ISEage:~$
```

By looking at the screenshots above, we can say that this Ubuntu was released on October 18, 2012, and its End of life date is May 16,2014.

10. What is Scrat's favorite nut?
(5 points)

```
My favourite Nuts (highest to lowest)
1. Pistachios
2. Almonds
3. Walnuts
4. Cashews
5. Acorns
```

11. What is Sid's middle name?
(5 points)

```
sid:x:1003:1003:Sidious Francis Maximus,,,:/home/sid:/bin/bash
```

His middle name is Francis

12. What is the local IP address of “Manny’s Home”?

(5 points)

```
$ ifconfig
em0: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> mtu 1500
    options=1b<RXCSUM,TXCSUM,VLAN_MTU,VLAN_HWTAGGING>
    inet 192.168.1.2 netmask 0xffffff00 broadcast 192.168.1.255
    ether 00:50:56:21:fe:01
    media: Ethernet autoselect (1000baseTX <full-duplex>)
    status: active
```

From the screenshot above, we can see that the IP address is 192.168.1.2.

13. What is the name of Manny’s Nana?

(5 points)

```
$ cat /home/manny/family_tree.txt
Grandma Pelt      Grandpa Tusk      Grandma Fur(nanna)  Grandpa Mannfred
    \             /
    Code          I
Wilfred (dad)      Margarette (mom)
    \             /
    sudo apt-get install dos2unix
                Manny
$
```

Her nanna’s name is Fur.